

CyberSight

Business-Aware Vulnerability & Cyber Risk Prioritization Platform for E-Commerce Organizations

Document Type: Preliminary Project Concept, Problem Statement & Scope | Version: 0.2 (Revised)

CORE IDEA	prioritize vulnerabilities using technical severity, exploit likelihood, and business impact—not technical severity alone.
-----------	--

PROJECT CONCEPT

1. Concept Overview

CyberSight is a web-based cybersecurity decision-support platform designed for e-commerce organizations. Its purpose is to help security and IT teams prioritize known vulnerabilities by combining three complementary perspectives: technical severity, likelihood of exploitation, and business impact. The platform is not intended to replace vulnerability scanners, SIEM platforms, or incident-response tools. Instead, it adds organizational context to existing vulnerability intelligence so that teams can decide what should be addressed first.

TECHNICAL CVE / CVSS	EXPLOITABILITY EPSS / known exploitation	BUSINESS Asset criticality / impact
-------------------------	---	--

Core Risk Unit Definition

CyberSight explicitly defines the prioritized "Risk Item" as an identified CVE bound directly to a specific operational asset (e.g., CVE-2023-XXXX affecting Asset-01: Payment Gateway API). The system prioritizes these Asset-CVE pairs rather than treating vulnerabilities in isolation.

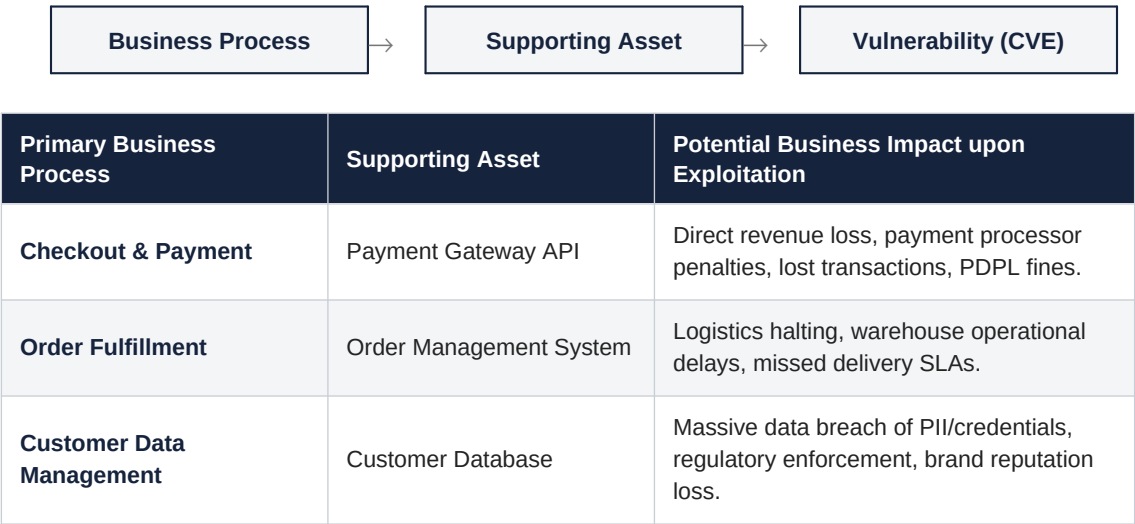
Target Context: The project specifically targets e-commerce organizations in Saudi Arabia, aligning with national cybersecurity baselines (NCA) while maintaining an underlying architecture applicable to e-commerce organizations in general.

2. Problem Statement

E-commerce organizations depend on interconnected digital assets such as web applications, customer databases, payment-related services, administrative portals, order-management systems, and supporting infrastructure. These assets may contain multiple known vulnerabilities at the same time. Security teams therefore face a practical prioritization problem: deciding which vulnerabilities require immediate attention when time, staffing, and remediation capacity are limited.

A purely technical view of vulnerability severity is not always sufficient for this decision. A vulnerability with a high technical severity score may exist on a low-criticality system, while another vulnerability with a lower technical score may affect a business-critical asset that supports online sales, customer data, order processing, or service availability. Treating both cases only by technical severity can lead to remediation priorities that do not fully reflect the organization's operational and business exposure.

Business-Aware Hierarchy & Impact Flow: CyberSight maps technical flaws to business exposure using a explicit 3-tier relationship:



The problem is therefore not simply the existence of vulnerability data, but the difficulty of translating technical vulnerability information into business-aware priorities. E-commerce organizations need a structured way to combine technical severity and exploit likelihood with the criticality and business impact of affected assets, then present the result in a form that supports

2.1 Clear Project Objectives

To directly address the problem statement and establish a clear project scope, CyberSight defines 5 core objectives:

1

Objective 1 (Asset & Criticality Modeling):

Formulate a structured 1–5 scoring rubric mapping e-commerce assets to business processes based on financial, operational, and data sensitivity dimensions.

2

Objective 2 (Data Enrichment Integration):

Build an automated data ingestion pipeline to integrate public vulnerability intelligence (NIST NVD) and exploit-likelihood indicators (FIRST EPSS).

3

Objective 3 (Explainable Prioritization Engine):

Implement an explainable scoring algorithm combining technical severity, exploitability, and asset criticality without black-box AI models.

4

Objective 4 (Decision-Support Dashboard):

Develop an interactive web dashboard providing risk visualization, transparent score breakdowns, and treatment status tracking.

5

Objective 5 (Empirical Evaluation):

Validate the platform by conducting a comparative evaluation against standard CVSS-only prioritization in a controlled e-commerce case study.

PROJECT BOUNDARIES

3. Project Scope

Scope definition. The graduation-project implementation of CyberSight will focus on vulnerability and cyber-risk prioritization for a controlled e-commerce organizational case study. The platform architecture may be extensible to other sectors in the future, but the design, data model, business-impact assumptions, demonstrations, and evaluation in this project will be centered on e-commerce organizations.

3.1 In Scope

- **E-commerce asset inventory:** Create and manage a limited set of representative assets such as the e-commerce web application, customer database, order-management system, administrative portal, inventory system, and supporting servers.
- **Public vulnerability intelligence:** Import or retrieve selected CVE records and associated technical attributes such as CVSS severity and affected-product information from trusted public sources.
- **Exploit-likelihood enrichment:** Enrich CVE records with EPSS scores and/or a known-exploitation indicator when available, so prioritization is not based on CVSS alone.

- **Business criticality assessment:** Assign each asset a structured business-criticality rating on a 1 to 5 scale based on criteria such as operational dependency, customer impact, data sensitivity (Saudi PDPL), financial impact, and service availability. Ratings are justified using a structured rubric form during asset setup.

Business-aware risk prioritization: Combine technical vulnerability information with asset criticality using an explainable Weighted Sum Model (WSM) aligned with NIST SP 800-30 and Saudi NCA NFCRM frameworks:

$$\text{Risk Score} = (0.35 \times \text{CVSS}) + (0.25 \times \text{EPSS} \times 10) + (0.40 \times \text{Asset Criticality} \times 2)$$

- **CVE-to-Asset mapping (Non-scanning approach):** Map vulnerabilities to assets without automated network scanning by recording asset software profiles (Software Bill of Materials / CPE entries) and correlating them against NIST NVD records or importing verified CVE files.
- **Risk treatment tracking:** Allow users to record a basic treatment decision or remediation status such as patch, mitigate, monitor, accept, or resolved.
- **Residual-risk view:** Provide a simplified before/after representation of risk when a treatment or security control is applied, without attempting to model every control in a full enterprise GRC framework.
- **Analytical dashboard:** Visualize high-priority vulnerabilities, risk distribution by asset, severity, exploitation likelihood, business criticality, and treatment status with transparent score component breakdowns.
- **Basic user roles:** Support a small set of roles such as Security Analyst and Security/IT Manager with role-appropriate access to assessment and reporting functions.

3.2 Out of Scope

- Automatic vulnerability scanning of real networks or endpoints.
- Penetration testing, exploitation, or offensive security functionality.
- Real-time network monitoring, intrusion detection, or SIEM replacement.
- Automated incident response or security orchestration (SOAR).
- Malware analysis or threat-hunting functionality.
- Direct integration with production systems of a real organization during the graduation-project phase.
- Full compliance auditing against every cybersecurity regulation or control framework.
- Prediction of future cyberattacks using a custom machine-learning model as a core dependency.

3.3 Data Scope and Availability

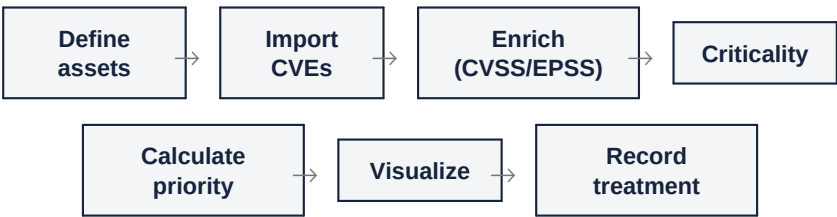
The project will deliberately use a hybrid data strategy so that the technical evidence is real while the organizational context remains safe, controllable, and feasible for a student project:

Data layer	Planned source	Role in CyberSight
Vulnerability records	NIST National Vulnerability Database (NVD)	CVE details, CVSS severity, affected-product information and other vulnerability attributes.
Exploit likelihood	FIRST EPSS	A probability-oriented exploitation score that can enrich prioritization.
Saudi context	Saudi National Cybersecurity Authority (NCA) & PDPL	E-commerce cybersecurity guidelines, NFCRM risk framework, and local data privacy compliance criteria.
Organizational context	Controlled synthetic e-commerce case study	Asset inventory, business processes, asset criticality and business-impact ratings created using a documented scoring rubric.

Important design principle: the synthetic component will not invent vulnerability facts. It will represent the organization-specific context that is normally private or unavailable, while CVE/CVSS/EPSS data will come from public real-world sources.

3.4 Minimum Viable Product (MVP) vs. Stretch Features

The MVP should remain intentionally small enough to be completed, tested, and demonstrated reliably. Features are strictly divided to guarantee feasibility:



CORE MVP (MUST IMPLEMENT)

- Manual asset creation & 1–5 rubric scoring.
- Selected CVE/CVSS import & static EPSS enrichment.
- Transparent WSM prioritization ranking engine.
- Analytics dashboard & basic treatment status tracking.

OPTIONAL STRETCH FEATURES

- Live NVD background API auto-sync pipeline.
- Dynamic admin weight customization sliders.
- Automated SLA timers & email notifications.
- One-click exportable executive PDF report generator.

3.5 Scope Boundaries for Feasibility

- The project will use a deliberately limited number of representative e-commerce assets rather than attempting to model a full enterprise environment.
- The vulnerability dataset will be a selected and relevant subset rather than a complete mirror of all global CVE records.
- The prioritization logic must be transparent and explainable; the core system will not depend on a black-box AI model.
- Advanced enrichment such as EPSS, local NCA relevance, or residual-risk comparisons can be implemented after the core MVP is stable.
- The project will be evaluated primarily as a decision-support information system: correctness of data handling, consistency of prioritization, usability, explainability, and usefulness for risk-triage decisions.

3.6 Realistic Stakeholders for Requirements & Validation

Requirements gathering and validation involve realistic academic and operational stakeholders:

- **Project Supervisor & Academic Faculty:** Evaluates theoretical rigor, methodology, and structural correctness.
- **Local Cybersecurity Practitioners / SOC Analysts:** Validates practical triage usability and real-world workflow relevance.
- **IT / Systems Administrators:** Validates asset software profile setup and maintenance tracking workflows.
- **Student Focus Group:** Participates in usability testing to evaluate dashboard navigation and score explainability.

3.7 Preliminary Project Evaluation Plan

CyberSight will be evaluated as a decision-support platform using a comparative experiment on a synthetic e-commerce dataset (6 assets, 20 CVEs):

- **Comparative Triage Experiment:** Compare baseline ranking (CVSS-only) against CyberSight business-aware ranking.
- **Evaluation Metrics:** Measure Priority Misalignment Rate (count of critical business risks deprioritized under CVSS) and conduct System Usability Scale (SUS) testing for analyst triage confidence.

Final Preliminary Scope Statement

CyberSight will be developed and evaluated as a web-based, business-aware vulnerability and cyber-risk prioritization platform for an e-commerce case study. It will combine real public vulnerability intelligence with

4. References

The following public sources support the vulnerability intelligence, exploit-likelihood data, Saudi regulatory context, and weight-derivation methodology used in this project.

- 1 National Institute of Standards and Technology (NIST). *National Vulnerability Database (NVD)*. Available at: <https://nvd.nist.gov/> — Public source of CVE records, CVSS base scores, and affected-product (CPE) data.
- 2 FIRST.org (Forum of Incident Response and Security Teams). *Exploit Prediction Scoring System (EPSS) Documentation*. Available at: <https://www.first.org/epss/> — Exploit-likelihood scoring used to enrich CVE records beyond CVSS alone.
- 3 Saudi National Cybersecurity Authority (NCA), in cooperation with the Saudi e-Commerce Council. (2019). *Cybersecurity Guidelines for E-commerce Service Providers (CGESP–1:2019)*. Available at: <https://nca.gov.sa/en/regulatory-documents/guidelines-list/cgec/> — Sector-specific cybersecurity guidance for e-commerce service providers, aligning the project with the Saudi target context.
- 4 Saudi National Cybersecurity Authority (NCA). (2025). *National Framework for Cybersecurity Risk Management (NFCRM–1:2025)*. Available at: <https://nca.gov.sa/en/regulatory-documents/frameworks-and-standard-list/nfcrm/> — National reference methodology for cybersecurity risk management in the Kingdom.
- 5 Saaty, T. L. (1980). *The Analytic Hierarchy Process: Planning, Priority Setting, Resource Allocation*. New York: McGraw-Hill — Source of the Analytic Hierarchy Process (AHP) methodology to be used for deriving the risk-scoring weights through stakeholder pairwise comparisons.